CERTIFIED ETHICAL HACKER | FOOTPRINTING AND RECONNAISSANCE

Footprinting

Concepts, Techniques, Tools and Countermeasures

Section	Topics covered
1	Footprinting concepts
2	Footprinting through search engines
3	Footprinting through web services
4	Footprinting through social networking sites
5	Website footprinting
6	Email footprinting
7	Competitive intelligence
8	Whois footprinting
9	DNS footprinting
10	Network footprinting
11	Footprinting through social engineering
12	Footprinting tools
13	Footprinting countermeasures
14-15	Quick revision sheet and practice questions

Important: Footprinting mostly uses public information, but active steps (querying a target's servers, contacting staff) can be intrusive or illegal without permission. Use these techniques only on organizations you own or have **written authorization** to assess, and respect privacy and local law.

Contents

1. Footprinting Concepts 3

2. Footprinting through Search Engines 4

3. Footprinting through Web Services 5

4. Footprinting through Social Networking Sites 5

5. Website Footprinting 6

6. Email Footprinting 7

7. Competitive Intelligence 7

8. Whois Footprinting 8

9. DNS Footprinting 9

10. Network Footprinting 10

11. Footprinting through Social Engineering 10

12. Footprinting Tools 11

13. Footprinting Countermeasures 12

14. Quick Revision Sheet 12

15. Practice Questions 13

1. Footprinting Concepts

What is footprinting?

Footprinting (reconnaissance) is the **first phase of ethical hacking**: collecting as much information as possible about a target organization, its network and its people, in order to understand its security posture, narrow the range of attack, and find weak points. The more complete the footprint, the easier the later phases (scanning, enumeration, gaining access) become.

Types of footprinting

Type	Description	Examples
Passive	Collects information **without interacting** with the target. Difficult for the target to detect.	Search engines, Whois, social media, job sites, archives, Shodan
Active	Interacts directly with the target; may leave traces in logs.	Traceroute, banner grabbing, email tracking, website mirroring, calling staff

Objectives

- **Know the security posture:** policies, controls, technologies in use
- **Reduce the attack surface:** focus on the most promising IP ranges, domains and systems
- **Identify vulnerabilities:** outdated software, exposed services, leaked data
- **Draw a network map:** topology, trusted routers, firewalls, servers

Information obtained

Category	Examples
Organization information	Employee details, phone numbers, locations, background, web technology, press releases, partners
Network information	Domain and sub-domain names, network blocks, IP addresses, Whois and DNS records, open ports, VPN gateways
System information	Web server OS, server locations, user accounts and passwords, software versions

Footprinting methodology

Search engines, then web services, social networking sites, website footprinting, email footprinting, competitive intelligence, Whois, DNS, network footprinting, and social engineering. The result is documented in a **footprint report** (hosts, IP ranges, technologies, people, risks). Open-source intelligence (**OSINT**) is the umbrella term for gathering this from public sources.

2. Footprinting through Search Engines

Search engines index vast amounts of public content, including pages the owner never meant to expose. Footprinting uses them to find sub-domains, internal pages, documents, login portals, error messages, and employee names.

Google advanced search operators (Google dorking)

Operator	Function	Example
site:	Limits results to a domain	site:example.com login
inurl:	Word must be in the URL	site:example.com inurl:admin
allinurl:	All words in the URL	allinurl:admin login
intitle:	Word in page title	intitle:"index of" backup
allintitle:	All words in title	allintitle:confidential report
intext:	Word in the body	intext:"password" site:example.com
filetype: / ext:	Specific file type	site:example.com filetype:pdf
cache:	Google's cached copy	cache:example.com
link: / related:	Pages linking to / similar to a site	related:example.com
info:	Summary info about a page	info:example.com
" " OR -	Exact phrase / alternatives / exclude	"annual report" -2019
* and ..	Wildcard / number range	"revenue 2020..2023"

Google Hacking Database (GHDB)

GHDB (on Exploit-DB) is a curated collection of dorks that find exposed files, login pages, error messages, vulnerable servers and sensitive directories. Use it to see what your own organization might be leaking.

Other search-based sources

- **Alternative engines:** Bing, DuckDuckGo, Yahoo, Baidu, Yandex, Ecosia (operators differ).
- **Video and image search:** YouTube, Google Images, reverse image search (TinEye, Google Lens) to track photo reuse and locations.
- **Meta search engines:** Dogpile, Startpage.
- **FTP search engines** for files on public FTP servers; **IoT and device search engines:** Shodan, Censys, Thingful.
- **Dark web search:** only with proper safeguards and authorization (Tor).

Searching your own organization with these operators is one of the cheapest security audits you can run.

3. Footprinting through Web Services

Service / source	What it provides
Netcraft	Site technology, hosting provider, server OS, uptime history, netblock owner
Shodan / Censys / Thingful	Internet-connected devices: banners, open ports, certificates, webcams, industrial systems
Wayback Machine (archive.org)	Old versions of a site: removed pages, old contact lists, retired technology
Sublist3r, crt.sh, Certificate Transparency	Sub-domains discovered from search engines and TLS certificate logs
SecurityTrails, DNSdumpster, ViewDNS	DNS history, sub-domains, reverse IP, related domains
Job sites (LinkedIn Jobs, Indeed, Glassdoor)	Technologies in use, software versions, team size, locations
Company and finance sites (SEC EDGAR, Crunchbase, OpenCorporates)	Subsidiaries, executives, acquisitions, financial data
People search (Spokeo, PeekYou, Pipl, 192.com)	Contact details, addresses, relatives, usernames
Geolocation (Google Earth, Google Maps, Wikimapia)	Office layouts, entrances, parking, surroundings
Code and paste sites (GitHub, GitLab, Pastebin)	Leaked credentials, API keys, internal hostnames, configuration
Breach/exposure checkers (Have I Been Pwned)	Whether staff emails appear in known breaches

theHarvester example (passive sources)

```
theHarvester -d example.com -b google,bing,crtsh -l 200   # emails, hosts, sub-domains
```

4. Footprinting through Social Networking Sites

Employees share more than they realise. Social platforms reveal who works where, reporting lines, technologies, travel, office photos, and personal details useful for social engineering or password guessing.

Platform	Typical information
LinkedIn	Job titles, roles, skills (technologies in use), employment history, connections, new hires
Facebook	Personal details, family, location check-ins, interests, photos
X (Twitter)	Real-time posts, complaints about systems, announcements, geotags
Instagram / TikTok	Photos and videos of workplaces, badges, screens, with possible metadata or location
GitHub / Stack Overflow	Code, commits with emails, technology stack, accidental secrets
Professional forums / Reddit	Support questions revealing products and configuration

Techniques and tools

- Check **friends/connections lists** and public groups to map relationships and find targets with weaker privacy settings.
- Use **username search** across platforms: Sherlock, WhatsMyName, Namechk, Social Searcher.
- Collect and correlate with **Maltego**, **Recon-ng**, **theHarvester**, **SpiderFoot**, **Sherlock**.
- Analyse **photo metadata** (EXIF: GPS, device model) and backgrounds for location clues.
- Fake or sock-puppet profiles may be used in authorized engagements to test staff awareness.

Never use real staff personal accounts outside the agreed scope of an engagement.

5. Website Footprinting

Website footprinting extracts information from the target's own website and web server, often passively through ordinary browsing, or actively with tools that probe it.

Information gathered

- Web server software and version, operating system, scripting languages, CMS and frameworks
- Sub-directories and files, parameters, hidden pages, admin portals
- Contact details, staff names, comments and developer notes in HTML source
- Cookies and session handling, JavaScript libraries, third-party services

Techniques

Technique	Detail and tools
Web server banner / headers	Server and X-Powered-By headers. curl -I, Netcraft, Burp Suite, ZAP, Wappalyzer.
Technology profiling	BuiltWith, Wappalyzer, WhatWeb, Netcraft Toolbar.
Source code review	View-source for comments, hidden fields, internal URLs, API endpoints.
robots.txt and sitemap.xml	Reveal directories that owners want hidden from search engines.
Cookies	Names and flags may reveal platform (PHPSESSID, ASP.NET_SessionId, JSESSIONID).
Spidering / crawling	Burp Spider, OWASP ZAP, Web Data Extractor, Scrapy; builds a map of pages.
Web mirroring	Copy a site offline for analysis: HTTrack, WebCopier Pro, wget -m, Cyotek WebCopy.
Website archive	Wayback Machine for past content and removed pages.
Website change monitoring	Visualping, Change Detection, WebSite-Watcher.
Metadata extraction	Documents contain author, software, paths: FOCA, ExifTool, Metagoofil.
Custom wordlists	CeWL spiders a site to create a word list for later password testing.

```
curl -I https://www.example.com                # response headers
whatweb https://www.example.com                # technology fingerprint
wget -m -p -k -e robots=off https://www.example.com   # mirror (authorized only)
exiftool report.pdf                            # author, software, creation date
cewl -d 2 -m 5 https://www.example.com -w words.txt   # wordlist from site
```

6. Email Footprinting

Email footprinting tracks and analyses email to learn about the recipient and the infrastructure. It is an **active** technique because the recipient's system (or mail server) interacts with your message.

Information gained

- When the email was received, read and forwarded; how long it was opened
- Recipient's IP address, approximate location, device and browser/OS, mail client
- Links clicked, attachments opened, number of times read
- Mail servers and the path the message took (from header analysis)

How tracking works

- A **tracking pixel**, a 1x1 transparent image with a unique URL, loads when the mail is opened and logs the request (IP, user agent, time).
- **Read receipts** and tracked links redirect through a logging server before reaching the real URL.
- **Disposition-Notification-To** and similar headers request receipts.

Email header analysis

Header	What it reveals
From / Reply-To / Return-Path	Apparent sender and bounce address (can be forged)
Received (read bottom to top)	Each mail server that handled the message, with IPs and timestamps
X-Originating-IP / X-Mailer	Sender's IP and client software when present
Message-ID	Unique identifier; domain part can show the sending system
Authentication-Results, SPF, DKIM, DMARC	Whether the sender domain was authenticated

Tools: eMailTrackerPro, PoliteMail, Yesware, Mailtrack, Infoga (find email addresses), Hunter.io, Email Header Analyzer (MXToolbox, Google Admin Toolbox).

7. Competitive Intelligence

Competitive intelligence is the systematic, legal gathering and analysis of information about competitors and the market: products, strategy, finances, staffing and technology. Footprinting uses it to learn about the target from the outside.

Information and sources

Information	Sources
Company history, size, structure	Company website, Hoovers, LexisNexis, Crunchbase, annual reports
Financials and filings	SEC EDGAR (10-K, 10-Q), Companies House, MarketWatch, Reuters
Products, plans and releases	Press releases (Business Wire, PR Newswire), trade shows, product pages
Patents and trademarks	USPTO, WIPO, Google Patents, Espacenet
Web traffic and audience	SimilarWeb, Alexa-type rankings, Compete
Employee sentiment and hiring	Glassdoor, LinkedIn, Indeed

Information	Sources
Brand mentions and news	Google Alerts, Twilert, Mention, Giga Alerts, social listening tools

Why testers care: job postings reveal technologies (for example 'Cisco ASA, Windows Server 2012'); filings reveal subsidiaries and acquisitions, which often have weaker security and live on the same network.

8. Whois Footprinting

Whois is a query-and-response protocol (TCP port 43) for looking up registration data of domain names and IP address blocks.

Domain Whois record contains

- Domain name, registrar, registrant, administrative and technical contacts (names, emails, phone numbers)
- Creation, update and expiry dates; domain status
- Authoritative name servers

IP Whois (RIR) contains

- Network range (netblock, CIDR), organization that owns it, upstream provider, abuse contact

Regional Internet Registry	Region
ARIN	North America
RIPE NCC	Europe, Middle East, parts of Central Asia
APNIC	Asia-Pacific
LACNIC	Latin America and the Caribbean
AFRINIC	Africa

```
whois example.com                  # domain registration record
whois 93.184.216.34                # IP netblock owner (RIR record)
whois -h whois.arin.net 8.8.8.8    # query a specific registry
```

Tools and notes

- Web tools: ICANN Lookup, ARIN Whois, DomainTools, Whois.com, Whois Lookup (SmartWhois, Batch IP Converter).
- **Reverse Whois** finds other domains registered by the same email or organization.
- Many registrars now apply **privacy protection / GDPR redaction**, hiding personal contact data. Historical Whois may still show older details.

Whois data helps you identify the registrant for the engagement scope and find social-engineering targets and the netblocks that belong to the target.

9. DNS Footprinting

DNS translates names to IP addresses. Querying DNS reveals hosts, mail servers, name servers and network layout, often with no direct contact with the target's own servers.

Record	Purpose
A / AAAA	Hostname to IPv4 / IPv6
MX	Mail servers for the domain
NS	Authoritative name servers
CNAME	Alias for another name
SOA	Primary NS, admin contact, serial, refresh timers
PTR	Reverse lookup: IP to name
SRV	Location of services (LDAP, SIP, Kerberos)
TXT	SPF, DKIM, DMARC, verification tokens
HINFO	Host CPU and OS (rarely published)

Techniques

- **Record lookups:** nslookup, dig, host.
- **Zone transfer (AXFR):** if allowed, returns the whole zone.
- **Reverse DNS:** sweep a netblock for PTR records.
- **Sub-domain brute force and passive sources:** wordlists, certificate transparency, search engines, passive DNS.
- **DNS cache snooping** to see which sites a resolver has recently looked up.

```
nslookup -type=MX example.com
nslookup -type=NS example.com
dig example.com ANY +noall +answer
dig axfr example.com @ns1.example.com        # zone transfer attempt
dnsrecon -d example.com -t std,brt            # standard + brute force
dnsenum example.com
fierce --domain example.com
sublist3r -d example.com
```

Web tools: DNSdumpster, SecurityTrails, ViewDNS.info, MXToolbox, DNSChecker, crt.sh. Tools like DNSRecon and dnsenum combine many checks in one run.

10. Network Footprinting

Network footprinting discovers the **network range** and the **path** to the target to build a topology map.

Finding the network range

- Whois / RIR lookup of the organization's IP addresses gives the netblock (for example 203.0.113.0/24).
- ARIN search by organization name; check BGP/ASN tools (bgp.he.net) to see all ranges announced by an AS.

Traceroute

Traceroute reveals the hops between you and the target. It sends packets with increasing **TTL** (Time To Live) values; each router decrements TTL, and when it reaches 0 the router returns an **ICMP Time Exceeded** message, revealing its address. The final host answers with an echo reply (or a port unreachable for UDP traceroute).

Platform	Command	Default probe
Windows	tracert example.com	ICMP echo
Linux / macOS	traceroute example.com	UDP (high ports)
Linux	traceroute -I example.com	ICMP echo
Linux	traceroute -T -p 443 example.com	TCP SYN (passes firewalls that allow 443)
Nmap	nmap --traceroute example.com	Uses the scan's probe type

Tools

Path Analyzer Pro, VisualRoute, NetScanTools Pro, Traceroute NG, Nmap, Hping3 (hping3 --traceroute), online traceroute services. Compare traces to detect load balancers, firewalls (hops that stop answering) and the number of network hops. The results feed the network diagram used later in scanning.

11. Footprinting through Social Engineering

Social engineering manipulates people into revealing information or performing actions. In footprinting it is used to collect details that cannot be found online, such as internal procedures, software in use and employee names. It is **active** and targets human trust, helpfulness, fear and urgency.

Technique	Description
Eavesdropping	Listening to conversations or intercepting messages.
Shoulder surfing	Watching someone enter credentials or read their screen.
Dumpster diving	Searching discarded paper, drives, sticky notes and receipts for data.
Impersonation	Posing as IT support, a vendor, auditor or new hire (in person or by phone).
Pretexting	Inventing a believable scenario to justify questions.
Phishing / vishing / smishing	Email, voice call or text message attacks that trick people into disclosing data.
Tailgating / piggybacking	Following an authorized person through a secured door.
Reverse social engineering	Creating a problem so the victim asks the attacker for help.

Information that can be gathered: names, extensions, org charts, software versions, security policies, badge designs, visitor procedures. Authorized tests need a signed scope, rules of engagement and a plan for handling

what staff disclose.

12. Footprinting Tools

Tool	Purpose
Maltego	Graph-based OSINT; links people, domains, emails, IPs and social accounts through transforms.
Recon-ng	Modular reconnaissance framework (similar to Metasploit's interface) with a database and API-key support.
theHarvester	Collects emails, sub-domains, hosts, names from search engines and APIs.
SpiderFoot	Automated OSINT collection across hundreds of sources.
OSINT Framework	Directory of OSINT tools and resources by category.
FOCA / Metagoofil / ExifTool	Download documents and extract metadata.
Shodan / Censys	Search engines for internet-connected devices and certificates.
Sherlock / Social Searcher	Username and social media search.
Netcraft / BuiltWith / Wappalyzer	Website technology profiling.
HTTrack / wget	Website mirroring.
nslookup / dig / dnsrecon / dnsenum	DNS queries and brute-forcing.
Whois / DomainTools	Registration data.
traceroute / Path Analyzer Pro / VisualRoute	Network path mapping.
eMailTrackerPro / Infoga	Email tracking and email address gathering.
OSRFramework, Photon, Metasploit auxiliary modules	Additional OSINT and crawling helpers.

Recon-ng basic workflow

```
recon-ng
[recon-ng][default] > workspaces create lab1
[recon-ng][lab1] > marketplace install recon/domains-hosts/hackertarget
[recon-ng][lab1] > modules load recon/domains-hosts/hackertarget
[recon-ng][lab1][hackertarget] > options set SOURCE example.com
[recon-ng][lab1][hackertarget] > run
[recon-ng][lab1] > show hosts
```

Module names and marketplace availability change between versions; use *marketplace search* and *help* in your installed version.

13. Footprinting Countermeasures

Area	Countermeasures
Search engines and web	Restrict what is indexed (robots.txt is not security: use authentication); remove sensitive files; regularly dork your own domain; request removal of cached content.
Web servers	Remove or alter banners and version headers; disable directory listing; strip metadata from published documents; keep CMS and plugins patched.
Social networking	Security awareness training; social media policy; limit what staff share about technology, badges and locations; privacy settings; separate personal and work accounts.
Email	Block tracking pixels and remote images by default; disable automatic read receipts; configure SPF, DKIM and DMARC; use email filtering and header-sanitising gateways.
Whois	Use domain privacy protection with role-based contact addresses; keep registration data accurate but minimal.
DNS	Restrict zone transfers to authorised servers; split-horizon DNS (separate internal and external zones); avoid HINFO and descriptive names; use DNSSEC; monitor for abnormal queries.
Network	Filter ICMP and TTL-expired replies where appropriate; limit traceroute visibility; segment networks; keep an accurate asset inventory.
Social engineering	Verification procedures for callers, visitor management, shredding, clean-desk policy, tailgating controls, phishing simulations.
Organisation	Classify information; review job adverts for technical detail; run periodic footprinting exercises against yourself; use OSINT monitoring and brand alerts.

14. Quick Revision Sheet

Topic	Remember
Footprinting	First phase. Passive (no contact) vs active (direct interaction).
Google operators	site:, inurl:, intitle:, intext:, filetype:, cache:, related:, info:; GHDB has ready dorks.
Web services	Netcraft, Shodan, Censys, Wayback, SecurityTrails, crt.sh, job sites, GitHub/Pastebin.
Social sites	LinkedIn for roles/tech, Facebook/Instagram personal data; Sherlock, Maltego, Recon-ng.
Website	Banners, source, robots.txt, cookies, mirroring (HTTrack), metadata (FOCA), CeWL.
Email	Tracking pixel, read receipt, header analysis (Received, X-Originating-IP); eMailTrackerPro.
Competitive intel	SEC EDGAR, patents, trademarks, Hoovers, job posts, Google Alerts.
Whois	TCP 43; registrar, registrant, name servers, dates; RIRs: ARIN, RIPE, APNIC, LACNIC, AFRINIC.
DNS	A, MX, NS, SOA, PTR, SRV, TXT; zone transfer AXFR; dnsrecon, dnsenum, dig.
Network	Netblock via RIR; traceroute uses TTL and ICMP Time Exceeded; tracert on Windows.
Social engineering	Eavesdropping, shoulder surfing, dumpster diving, impersonation, phishing, tailgating.
Countermeasures	Privacy settings, banner removal, restricted zone transfers, awareness training, DNS split-horizon.

15. Practice Questions

#	Question	Answer
1	Which type of footprinting does not interact directly with the target?	Passive footprinting.
2	Which Google operator restricts results to one domain?	site:
3	What is the GHDB?	The Google Hacking Database: a collection of search queries (dorks) that find sensitive exposed information.
4	Which TCP port does the Whois protocol use?	43.
5	Which RIR serves Europe?	RIPE NCC.
6	Name the DNS record that lists the mail servers of a domain.	MX.
7	What does a DNS zone transfer return, and how is it prevented?	The full zone data; restrict AXFR to authorised secondary servers (and use TSIG).
8	How does traceroute discover routers on the path?	It sends packets with increasing TTL; each router that drops one returns ICMP Time Exceeded.
9	Which Windows command performs a trace route?	tracert.
10	How does a tracking pixel work in email footprinting?	A tiny image with a unique URL loads when the mail is opened, so the server logs the recipient's IP, time and client.
11	Which file may reveal directories a site owner wants hidden from search engines?	robots.txt.
12	Name two tools for website mirroring.	HTTrack and WebCopier (also wget).
13	What type of data does FOCA extract from documents?	Metadata: author names, software, usernames, paths and dates.
14	Which technique involves searching discarded papers and media?	Dumpster diving.
15	Give two countermeasures against footprinting.	Examples: privacy protection on Whois, removing banners, restricting zone transfers, awareness training, filtering email tracking.

Practice only on your own lab or in-scope targets, and keep notes of each source and date for your report.